

PRODUCT REQUIREMENTS DOCUMENT



Detektor QR Code Berbahaya untuk Pengguna QRIS Indonesia

OVERVIEW

Nama Aplikasi	QRisk
Versi PRD	1.0
Timeline	Sprint 1: 23 Juni - 4 Juli 2026 Sprint 2: 5 - 11 Juli 2026 Sprint 3: selesai paling lambat 11 Juli 2026
Kompetisi	Hackathon Wreck-IT 7.0 - Subtema: Autonomous Defense & AI-Driven Threat Hunting
Bahasa Aplikasi	Bahasa Indonesia (seluruh antarmuka, notifikasi, dan penjelasan verdict)
Platform	Mobile - Android & iOS (Flutter cross-platform)
Link Figma	[isi setelah design selesai]
Link GitHub	[isi setelah repo dibuat]

Target User

Pengguna aktif QRIS di Indonesia, terutama masyarakat umum yang rutin melakukan pembayaran digital di merchant fisik, dengan tingkat literasi keamanan siber rendah hingga menengah. Mencakup pelajar, pekerja kantoran, pelaku UMKM, dan masyarakat umum berusia 15-55 tahun yang menggunakan smartphone Android atau iOS.

Konsep

QRisk adalah aplikasi keamanan siber berbasis mobile yang menganalisis keamanan URL di dalam QR code sebelum browser dibuka. Sistem bekerja dalam tiga lapis: heuristic engine offline (on-device), backend proxy FastAPI + Redis, dan tiga API threat intelligence eksternal (VirusTotal, Google Safe Browsing, IPQualityScore). Hasil analisis disampaikan dalam tiga kategori verdict berbahasa Indonesia: ✓ AMAN, ⚡ WASPADA, dan ⚠ BAHAYA, lengkap dengan penjelasan kontekstual dan rekomendasi tindakan yang mudah dipahami pengguna awam.

TIM PENGEMBANG

Role	Nama	Fokus Tanggung Jawab
Product Manager - Design & Proposal	Trisha	Riset pengguna, proposal teknis, dokumentasi BAB I-IV, koordinasi design system dan konten antarmuka
Product Manager - Technical & Cybersecurity	Ari	Arsitektur sistem, kebijakan threat intelligence, kalibrasi weighted scoring, manajemen backlog teknis, risk assessment
Frontend / Mobile Engineer	Mevya	Implementasi Flutter (scanner screen, verdict UI, scan history, offline mode, haptic feedback, animasi corner bracket)
Backend Engineer	Astro	FastAPI proxy, Redis cache, paralel API call, URL shortener resolver, deploy Railway, rate limiter, background sync blocklist
ML Engineer	Nopas	Offline heuristic engine, typosquatting detection model, TLD analysis, IDN homograph detection, training dataset lokal Indonesia (target selesai Sprint 3 / 11 Juli 2026)

PROBLEM STATEMENT

Ekosistem QRIS Indonesia memiliki 57,6 juta pengguna aktif dengan 6,24 miliar transaksi senilai Rp659,93 triliun pada 2024 (Bank Indonesia, 2025). Namun, seluruh QR code scanner konvensional, termasuk scanner bawaan perangkat dan Google Lens, langsung membuka browser tanpa memeriksa keamanan URL terlebih dahulu. Quishing (QR code phishing) tumbuh 587% antara 2022-2023, BSSN mencatat 26,77 juta aktivitas phishing di Indonesia sepanjang 2024, dan rata-rata kerugian per insiden telah mencapai USD 4,88 juta (IBM Security, 2025). Sebanyak 73% pengguna smartphone memindai QR code tanpa memverifikasi tujuan tautan (NordVPN, 2025), sementara 74,59% masyarakat Indonesia tidak menyadari pernah menjadi korban serangan siber (APJII, 2023).

 SOLUTION

QRisk menempatkan lapisan analisis keamanan komprehensif di antara momen pemindaian dan momen browser dibuka. Payload QR diekstrak dan dinilai oleh sistem multi-lapis sebelum tautan dieksekusi, mengubah pengguna dari subjek pasif menjadi pihak yang mendapat asesmen risiko berbasis data. Verdict disampaikan dalam bahasa Indonesia yang mudah dipahami (AMAN / WASPADA / BAHAYA) beserta penjelasan ancaman dan rekomendasi tindakan, sehingga menutup kesenjangan literasi keamanan digital secara langsung di titik risiko.

 SISTEM VERDICT (AMAN / WASPADA / BAHAYA)

Seluruh UI, notifikasi, label, dan penjelasan ancaman **WAJIB** menggunakan Bahasa Indonesia. Verdict adalah output utama yang dilihat pengguna.

Verdict	Skor	Warna UI	Perilaku Sistem	Aksi Pengguna
✓ AMAN	0 - 25	Hijau (#1B7F4E)	Browser dibuka otomatis. Tidak ada interupsi pengguna.	Tidak diperlukan tindakan manual.
⚡ WASPADA	26 - 65	Kuning (#B45309)	Bottom sheet muncul, menampilkan preview domain dan jenis indikator mencurigakan.	Tombol 'Buka Tetap Hati-hati' atau 'Batalkan'.

⚠ BAHAYA	66 - 100	Merah (#B91C1C)	Akses diblokir sepenuhnya. Penjelasan ancaman terperinci dalam Bahasa Indonesia.	Opsi 'Laporkan ke BSSN' tersedia langsung dari layar.
-----------------	----------	--------------------	---	---

Distribusi Bobot Scoring

Sumber	Bobot	Keterangan
VirusTotal API v3	40%	70+ engine antivirus, kuota 500 req/hari gratis
Google Safe Browsing v4	35%	Deteksi phishing & malware skala global, gratis
IPQualityScore API	15%	Fraud score, domain age, anomali DNS, 5.000 req/bulan gratis
Heuristic Engine (Offline)	10%	Berjalan penuh tanpa koneksi internet, dikembangkan oleh ML Engineer

⚙ FEATURES

1. QR Scanner dengan Pra-Redirect Interception		[Frontend]	In progress ▾
Deskripsi	Kamera memindai QR code menggunakan flutter_zxing (~30fps). Payload URL diekstrak dan dikirim ke pipeline analisis sebelum browser menerima perintah redirect. Ini adalah perbedaan arsitektural fundamental dibanding scanner konvensional.		
Goal	Mencegah pengguna mengakses URL berbahaya sebelum menyadarinya.		
Constraint	- Decode terjadi sebelum browser dibuka (pre-redirect, bukan post-redirect) - Mendukung semua format QR code standar - Menangani QR code QRIS yang encode data non-URL (tampilkan info transaksi, bukan redirect)		

UI / Copywriting	• Scanner screen dengan animasi corner bracket (flutter_animate) • Overlay loading saat analisis berjalan (<3 detik) • Haptic feedback berbeda per kategori verdict (vibration package)
-------------------------	--

2. Offline Heuristic Engine		[ML Engineer]	Not started ▾
Deskripsi	Engine lokal yang mendeteksi pola quishing tanpa koneksi internet. Mencakup typosquatting merek lokal Indonesia, TLD mencurigakan dalam konteks QRIS, subdomain abuse, IDN homograph attack, dan URL shortener resolver.		
Goal	Memberikan proteksi dasar bahkan di area tanpa sinyal, target training selesai Sprint 3 (11 Juli 2026).		
Constraint	• Deteksi: typosquatting BRI, BCA, GoPay, Tokopedia, OVO, Dana, Mandiri, Shopee • Deteksi TLD berisiko dalam konteks QRIS (.xyz, .tk, .click, .top, dll.) • Deteksi subdomain abuse (misal: tokopedia.evil.com) • Deteksi IDN homograph attack • Resolve URL shortener (bit.ly, s.id, t.co) via HEAD request ke final URL • Latensi <50ms on-device • Akurasi target >90% pada dataset uji lokal		
UI / Copywriting	• Badge 'Scan offline: akurasi terbatas' saat mode offline aktif		

3. Multi-Source Threat Intelligence (Cloud Check)		[Backend]	Not started ▾
Deskripsi	Tiga API threat intelligence dipanggil secara paralel via FastAPI proxy menggunakan mekanisme Promise.all/Future.wait(). Total latensi setara API paling lambat, bukan penjumlahan ketiganya.		

Goal	Mendapatkan verdict akurat dalam <3 detik dengan cakupan database threat intelligence global.
Constraint	• Paralel call: VirusTotal v3, Google Safe Browsing v4, IPQualityScore • Timeout per API: 2,5 detik; fallback ke heuristic-only jika semua gagal • API key tersembunyi di backend proxy (tidak ada di sisi klien) • Cache Redis TTL 24 jam di level backend • Rate limiter untuk mencegah abuse kuota
UI / Copywriting	• Indikator spinner 'Menganalisis keamanan tautan...' (Bahasa Indonesia)

4. Weighted Scoring Engine & Verdict Display		[Backend + Frontend]	Not started ▾
Deskripsi	Agregasi hasil empat sumber (VirusTotal 40%, Google Safe Browsing 35%, IPQualityScore 15%, Heuristic 10%) menjadi skor komposit 0-100. Skor dipetakan ke tiga verdict dengan threshold yang dikalibrasi dari dataset QR berbahaya nyata.		
Goal	Menyampaikan verdict yang akurat, terukur, dan dapat dipahami pengguna awam berbahasa Indonesia.		
Constraint	• Skor 0-25: AMAN, skor 26-65: WASPADA, skor 66-100: BAHAYA • Seluruh teks verdict dan penjelasan dalam Bahasa Indonesia • Verdict WASPADA: bottom sheet dengan preview domain, indikator yang ditemukan, dan dua tombol aksi • Verdict BAHAYA: layar blokir penuh + penjelasan ancaman terperinci + opsi lapor ke BSSN • Verdict AMAN: browser dibuka otomatis tanpa interupsi		
UI / Copywriting	• Badge warna per verdict (hijau/kuning/merah) • Penjelasan ancaman dalam Bahasa Indonesia yang mudah dipahami awam • Tombol 'Laporkan ke BSSN' di layar BAHAYA		

5. Privacy-by-Design Architecture		[Backend + Frontend]	Not started ▾
Deskripsi	Tidak ada data identitas pengguna yang keluar dari perangkat. URL yang dianalisis dikirim ke API pihak ketiga hanya melalui backend proxy anonim. Backend mencatat statistik anonim, bukan data personal.		
Goal	Menjaga kepercayaan pengguna dan kepatuhan privasi.		
Constraint	• Zero PII (Personally Identifiable Information) ke server eksternal • URL dikirim melalui FastAPI proxy terenkripsi (HTTPS/TLS 1.3) • Backend hanya menyimpan statistik anonim (jumlah scan, distribusi verdict) • Tidak ada akun/login wajib untuk menggunakan fitur inti		
UI / Copywriting	• Halaman 'Tentang Privasi' dalam Bahasa Indonesia accessible dari menu		

6. Scan History & Local Cache		[Frontend + Backend]	Not started ▾
Deskripsi	Riwayat scan disimpan di SQLite lokal perangkat. Cache TTL 24 jam mencegah re-query untuk domain yang sama dalam sehari. Blocklist 10.000 domain berbahaya ter-bundle dalam aplikasi dan diperbarui mingguan via background sync.		
Goal	Efisiensi penggunaan kuota API dan kemudahan review riwayat scan oleh pengguna.		
Constraint	• SQLite lokal via sqflite (tidak di-sync ke server) • Shared preferences untuk result cache berbasis TTL 24 jam • Background sync blocklist mingguan via workmanager • Blocklist bundled: 10.000 domain berbahaya terpopuler		
UI / Copywriting	• Halaman 'Riwayat Scan' dengan filter AMAN/WASPADA/BAHAYA • Card per hasil scan: domain, waktu, badge verdict, skor		



MILESTONE (SPRINT PLAN)

Deadline akhir Sprint 3: 11 Juli 2026. ML Engineer harus menyelesaikan training heuristic model sebelum atau pada tanggal itu

Sprint	Role	Task Utama
Sprint 1 (Fondasi) 23 Jun - 4 Jul	PM Design & Proposal	Riset modus quishing Indonesia; analisis gap 10 scanner QR populer; buat dokumen problem statement & user persona; mulai design system dark navy/cyan di Figma
	PM Technical & Cybersecurity	Buat PRD (dokumen ini); definisikan backlog teknis Sprint 1-3; rancang arsitektur tiga lapis; kalibrasi awal bobot scoring
	Frontend	Setup project Flutter 3.x + Dart; integrasi kamera & flutter_zxing; buat prototype scanner dasar yang decode QR sebelum browser dibuka
	Backend	Setup FastAPI + Redis; buat endpoint proxy dasar; implementasi URL shortener resolver (HEAD request)
	ML Engineer	Kumpulkan dataset quishing lokal Indonesia (BSSN, PhishTank); desain arsitektur heuristic engine; mulai riset model typosquatting detection
Deliverables	• Prototype scanner dasar (decode pre-redirect) • Design system Figma & wireframe 8 screen utama • PRD final • Arsitektur sistem terdokumentasi • Dataset quishing lokal terkumpul	

Sprint	Role	Task Utama
Sprint 2 (Inti Deteksi) 5 Jul - 11 Jul	PM Design & Proposal	Finalisasi wireframe & prototype Figma; supervisi konten copywriting Bahasa Indonesia di semua screen; mulai draft BAB III pembahasan

	PM Technical & Cybersecurity	Review akurasi heuristic engine; kalibrasi threshold skor berdasarkan hasil pengujian; koordinasi integrasi API
	Frontend	Implementasi UI lengkap: scanner screen, bottom sheet verdict (WASPADA), layar blokir (BAHAYA), layar konfirmasi (AMAN); animasi corner bracket; haptic feedback per verdict; halaman riwayat scan
	Backend	Integrasi tiga API paralel (VirusTotal v3, Google Safe Browsing v4, IPQualityScore); implementasi weighted scoring engine; Redis cache; rate limiter; deploy ke Railway free tier
	ML Engineer	Training & validasi heuristic engine (typosquatting, TLD, subdomain, IDN homograph); buat blocklist SQLite 10.000 domain; bundle ke aplikasi; target akurasi >90%
Deliverables	• Pipeline deteksi end-to-end fungsional (<3 detik) • Heuristic engine dengan akurasi >90% (WAJIB selesai 11 Jul) • Modul cloud check paralel • Backend live di Railway • UI flutter lengkap dengan semua verdict screens	

Sprint	Role	Task Utama
Sprint 3 (Finalisasi) ≤ 11 Jul 2026	PM Design & Proposal	Finalisasi dokumentasi proposal (BAB IV Penutup: Kesimpulan & Saran); review keseluruhan dokumen; persiapan materi presentasi
	PM Technical & Cybersecurity	Pengujian 50+ skenario QR berbahaya nyata termasuk QRIS palsu; finalisasi laporan hasil pengujian; persiapan demo
	Frontend	Polish UI/UX; implementasi halaman 'Tentang Privasi'; background sync UI; testing device Android & iOS; bug fixing

	Backend	Konfigurasi background sync blocklist mingguan (workmanager); pengujian integrasi penuh; logging anonim; optimasi performa
	ML Engineer	Finalisasi model & blocklist; integrasi ke aplikasi Flutter; validasi end-to-end; pastikan offline mode berjalan tanpa koneksi
Deliverables	• Aplikasi Flutter siap demo dengan UX penuh • Repositori GitHub publik • Dokumen proposal final (BAB I-IV + Lampiran) • Laporan hasil pengujian 50+ skenario • Laporan ML: akurasi & dataset	

TECH STACK

Layer	Teknologi	Justifikasi
Mobile Framework	Flutter 3.x + Dart	Cross-platform Android/iOS dari satu codebase, performa native, ekosistem scanner real-time
QR Decoding	flutter_zxing + mobile_scanner	Decode ~30fps, Dart FFI stabil, decode sebelum browser dibuka
URL Parsing	uri (native Dart) + tldts	Parsing TLD & subdomain akurat, deteksi IDN homograph, resolve URL shortener
Local Storage	sqflite + shared_preferences	SQLite untuk blocklist 10.000 domain; shared_prefs untuk cache TTL 24 jam
Threat Intelligence	VirusTotal v3, Google Safe Browsing v4, IPQualityScore	70+ engine AV (VT), phishing global (GSB), fraud score + DNS anomali (IPQS)
HTTP Client	dio + Future.wait()	Paralel call - total latensi = API paling lambat, bukan jumlah ketiganya; timeout & retry

State Management	Riverpod 2.x	Ringan, boilerplate minimal, mendukung async state untuk alur scan multi-operasi
UI Components	go_router, flutter_animate, vibration	Routing deklaratif, animasi corner bracket, haptic feedback berbeda per verdict
Backend Proxy	FastAPI (Python) + Redis	Sembunyikan API key dari klien; cache domain 24 jam; deploy Railway free tier
Background Sync	workmanager	Pembaruan blocklist lokal mingguan tanpa mengganggu UX utama

ARSITEKTUR SISTEM

Three-Tier Architecture

QRisk menggunakan arsitektur tiga lapis dengan prinsip privacy-by-design. Tidak ada data identitas pengguna yang meninggalkan perangkat.

Lapisan	Komponen & Fungsi
Lapisan 1 On-Device (Offline-Capable)	- Pemindai QR (flutter_zxing): decode payload sebelum browser dibuka - Parser URL (uri + tldts): normalisasi, deteksi shortener, resolve ke final URL - Heuristic Engine (ML Engineer): typosquatting, TLD, subdomain, IDN, latensi <50ms - Blocklist SQLite: 10.000 domain berbahaya, bundle + update mingguan - Cache hasil: shared_preferences TTL 24 jam
Lapisan 2 Backend Proxy (FastAPI + Redis)	- FastAPI Proxy: sembunyikan API key dari sisi klien (zero risk credential leak) - Rate Limiter: mencegah abuse kuota API gratis - URL Shortener Resolver: resolve bit.ly, s.id, t.co ke final URL - Redis Cache: agregat hasil domain TTL 24 jam - Statistik Anonim: jumlah scan & distribusi verdict (tanpa data personal)

	• Deploy: Railway free tier (keperluan demo hackathon)
Lapisan 3 External Threat Intelligence APIs	• VirusTotal API v3 (bobot 40%): 70+ engine antivirus, 500 req/hari gratis • Google Safe Browsing v4 (bobot 35%): phishing & malware global, gratis • IPQualityScore API (bobot 15%): fraud score, domain age, anomali DNS, 5.000 req/bulan • Semua dipanggil paralel via Future.wait() — total latensi $\leq$ API paling lambat merespons

⚠ ANALISIS RISIKO & MITIGASI

Risiko	Deskripsi	Mitigasi	Status
False Positive	URL aman terklasifikasi WASPADA/BAHAYA	Threshold dikalibrasi dari 50+ skenario nyata; user dapat override pada WASPADA	Dimitigasi
Kuota API Habis	VirusTotal 500/hari, IPQS 5.000/bulan	Cache TTL 24 jam; fallback ke heuristic-only mode dengan badge peringatan	Dimitigasi
Ancaman Zero-Day	Domain baru belum masuk database manapun	Heuristic engine berbasis pola struktural URL (usia domain, TLD, subdomain), bukan signature	Sebagian Dimitigasi
Downtime API Eksternal	VT/GSB/IPQS tidak tersedia	Arsitektur tiga lapis: sistem tetap jalan dalam mode offline via heuristic + blocklist	Dimitigasi
Evolusi Teknik Quishing	Teknik baru di luar heuristic rules	Blocklist update mingguan via background sync; pola heuristik berbasis karakteristik struktural yang sulit dimanipulasi	Sebagian Dimitigasi
Kuota ML Selesai Terlambat	Model belum ready sebelum Sprint 3 berakhir (11 Juli)	Training dimulai Sprint 1; checkpoint mingguan; jika	Dimitigasi (dipantau)

		belum mencapai >90%, gunakan rule-based fallback	
--	--	---	--

CATATAN

1. **Seluruh antarmuka, notifikasi, label fitur, penjelasan verdict, dan teks error WAJIB dalam Bahasa Indonesia.**
2. Deadline keras Sprint 3: 11 Juli 2026. ML Engineer wajib menyelesaikan training dan validasi heuristic model sebelum atau pada tanggal tersebut.
3. Sistem WAJIB mendukung mode offline (heuristic + blocklist) jika tidak ada koneksi internet. Badge 'Scan offline: akurasi terbatas' harus muncul. (kalau mau perfect)
4. Tidak ada data identitas pengguna (PII) yang boleh keluar dari perangkat. URL disampaikan ke API eksternal hanya melalui backend proxy terenkripsi.
5. Field Link Figma dan Link GitHub pada halaman pertama diisi segera setelah tersedia.